

Carrot Chase — MVP Technical Stack

Architecture and compliance report to accompany the full-stack diagram · May 2026

This report accompanies the MVP stack diagram. It sets out each component, the rationale behind the key decisions, and how the architecture meets the compliance obligations attached to processing children's personal data in UK schools.

STACK COMPONENTS

Browser / React SPA (Vercel)

The product is a single-page React application hosted on Vercel. Vercel provides global edge caching, automatic HTTPS, preview deployments per pull request, and zero-config CI from GitHub. For a small team shipping fast, the operational savings are significant. The SPA serves all three role-scoped dashboards (Super Admin, School Admin, Lead) from one code-base, routed at login on the JWT role claim.

The Lead's event execution screens (epic E6, the highest-priority and most complex flow in the product) are built as a Progressive Web App with offline support. All event data is pre-cached to IndexedDB while the device is still on WiFi, taps and name matches are recorded locally during the race, and the complete result set is synced to Supabase on reconnection. This matters because events run outdoors on school fields where mobile signal is often unreliable.

Supabase (eu-west-2, London)

Supabase consolidates five infrastructure components into one managed platform, hosted entirely in the London region to keep pupil data within the UK.

Auth issues JWTs containing role and organisation claims after login. Onboarding is invite-only across all five user types, and 2FA is mandatory for every role.

PostgREST auto-generates a REST API from the database schema, used by the SPA for non-sensitive operational reads and writes such as listing groups, fetching events, and rendering leaderboards. The schema discovery endpoint is disabled in production.

Edge Functions (Deno / TypeScript) handle all server-side logic. The most important are:

- The Carrot Algorithm, which recalculates runner levels after each event using the second-fastest time across the last five runs.
- Stagger calculation, producing the level-banded start order at event open.
- Custom invite token generation with 72-hour expiry, status tracking, and resend, dispatched via Resend.
- CSV member import, which validates uploaded pupil files and bulk-inserts valid rows with inline error feedback.
- Results commitment, which calculates adjusted finish times, assigns medals, flags personal bests and most improved, and triggers level recalculation.
- All queries that return children's personal data, routed through functions rather than PostgREST to produce a query audit trail.

PostgreSQL holds all platform data. The schema enforces the four-level hierarchy (Platform, Organisation, Group, Event) from the product specification. Several decisions must be locked in at schema design to avoid disruptive migrations later: a junction table for multi-group runner membership (US-13, the largest outstanding gap in the prototype), soft deletes on groups to preserve event history, a time-series results table to power the ten-event level progression chart, a dedicated invitation tokens table, and Stripe customer ID columns on organisations ready for Phase 2 billing.

Storage holds school logos, course maps, and CSV uploads during import processing.

Resend

All transactional email is sent through Resend, called from Edge Functions. This covers invite delivery, 2FA codes, and post-event result summaries.

Stripe (Phase 2)

Stripe Connect is shown in the diagram because the architecture is designed to accommodate it from day one, in line with the product specification. At MVP, billing is handled by manual invoicing from the Carrot team. When Phase 2 begins, the wiring is already in place: customer IDs exist on organisations, Edge Functions handle the webhook payloads, and the revenue split logic plugs in without a schema migration.

KEY ARCHITECTURAL DECISIONS

- **Web app first, no native build.** A well-built PWA delivers the full Lead event execution experience, including offline mode and large tap targets, at a fraction of the cost of native development. The product specification explicitly endorses this approach.

- **No Python service at MVP.** Supabase Edge Functions in TypeScript handle every server-side need at MVP, including the Carrot Algorithm. A Python service becomes relevant in Phase 3 if Arbor or Wonde MIS integration requires more complex data transformation.
- **No Strava integration at MVP.** Strava is a Phase 3 feature, related to adult runner profile seeding on the wider Carrot platform. It has no role in the school product.
- **Custom invite tokens rather than native Supabase invites.** The native flow does not support the full E1 requirements (72-hour expiry, visible invitation status, one-click resend). A custom token table managed by an Edge Function gives complete control and keeps the audit trail in the application database.

COMPLIANCE

The platform processes personal data relating to children, which carries a higher standard of care than ordinary personal data under UK GDPR. The following measures address the key obligations.

Lawful basis	Schools act as data controller, Carrot Chase as data processor. A Data Processing Agreement is required with each school before any pupil data is loaded.
Encryption in transit	All browser-to-Supabase traffic uses HTTPS, satisfying Article 32 on security of processing.
Access control	Row Level Security policies enforce the four-level data hierarchy at the database itself. Cross-organisation access is structurally impossible, not just blocked at the application layer.
Authentication	2FA is mandatory for all roles. No opt-out, no exceptions.
Audit trail	PostgREST does not log queries by default. All queries returning children's personal data are routed through Edge Functions, which produce invocation logs from day one.
Client-side security	JWTs stored in HttpOnly cookies to mitigate XSS-based token theft. RLS policy testing is part of the deployment checklist.
Data residency	All Supabase infrastructure runs in the London region. No pupil data leaves the United Kingdom.
Data subject rights	Erasure implemented as soft delete that anonymises personal fields while preserving aggregate results. Data portability via CSV export from the School Admin dashboard.
GDPR as positioning	The product specification identifies rigorous GDPR compliance as a competitive advantage when selling to schools. Every decision above is documented and defensible to a school data protection lead.

This document reflects the agreed MVP architecture and may evolve as Phase 2 features (Stripe integration, parent accounts, MAT leaderboards) move into scope.